

This captures questions and thoughts from the shadow and gives time to the AppSec Engineer to prepare quality answers before the next session.

Course Length:

5 days, 5-8 hours

Team Manager: Kymberlee Price @eelrebmyk, Vitor Meireles De Sousa @vdesousa

## Security Research

The Security Research Team is a multi-discipline team that seeks to answer the deep questions: "What can be done to detect malicious dependencies before they are known to be malicious?"; or "What is the attack surface of Kubernetes, and how does it apply to the GitLab Helm Chart?"; or "How can we do lightweight, but effective threat modeling as part of our SDLC?". We enjoy asking, and answering the questions that need depth to be answered, and working with other teams, inside and outside of security, to apply the findings to GitLab problems. Like any good research organization, we also look to share our findings with the wider security community, be it through responsible disclosure, blog posts, or participation in conferences.

Schedule / Topics Covered:

- SR101.1: Intro into Security Research w/ Ethan (1 hour)
- SR101.2a: Rabbit Hole 1 w/ Joern (1-2 hours)
- SR101.2b: Rabbit Hole 2 w/ Mark (1-2 hours)
- SR101.2c: Rabbit Hole 3 w/ Dennis (1-2 hours)

Course Length:

2 days, 6-8 hours

Team Manager: Ethan Strike @estrike

## Enrollment

Ready to enroll? [Click here](#) for more information.

---

## SECTION: security/security-shadow-security-assurance.md

## Security Compliance

Security Compliance: Where "Just do whatever you want" comes to die.

Have you ever wondered where all those security requests and requirements come from and why in the world you're always being asked to provide evidence and talk through how systems are designed and configured? Well then good news! Come join the security compliance team for a shadow rotation where we'll have you:

- Reading through information security framework documentation

- Reviewing system access
- Creating information security policies and standards
- Testing security controls to see if what we want to have happen within our systems is what's actually happening

#### Schedule / Topics Covered

##### SC101.1: Security Control Testing

- Understanding the spirit of a security control
- Common control requirements mapping
- Control implementation statements
- Evidence requests
- Test of design (TOD)
- Test of operating effectiveness (TOE)
- Observations, notes, and information output

##### SC101.2: Terminated User Access Review

- Overview of process
- Review of compliance requirements
- User listing requests
- Identifying terminated users
- Reporting back to system owners
- Review of access review automation

#### Course Length

3 days, 6-9 hours

#### Team Manager

Corey Oas @corey-oas

#### Field Security and Governance

Our goal on the Field Security team is to be the liaison between GitLab's Security Department and outside requests. We do this by providing sales enablement, evangelism and educational activities, and responding to customer concerns related to security. By proactively positioning the Field Security team in this way, we can effectively triage requests and facilitate communication while supporting our GitLab teammates.

#### Schedule / Topics Covered

##### FSG101: Sales Support and Self- Service Security

- Review various types of customer requests
- Demo of RFP repository of common questions
- Review of ZenDesk queue and requests
- Try it out- Pretend you are answering a questionnaire for a customer. Complete a mini

questionnaire using the resources discussed in this lesson.

### FSG102: The Face of Security

- Review ways we represent security in the public light (blog posts, events, training)
- Discuss certification requests and how we triage/review those requests
- Review a new request and discuss the gap analysis process
- Try it out- Write a paragraph (or full blog post) about something you learned during this course. Spread the GitLab security story!

### FSG103: Intro to Governance, Risk, and Compliance (GRC) Application

- Overview of the purpose of GRC tools
- Tour of GitLab's specific GRC application
- Inputs that feed into the GRC application
- Outputs generated by the GRC application
- Audit/assessment demo
- GRC application dashboarding/reporting

### Course Length

3 days, 4-6 hours

### Team Manager

Joe Longo @jlongogitlab

### Security Risk

The Security Risk team acts as a shield between GitLab and the dangers lurking within our environment. We do this by conducting third party assessments and security operational risk management activities to proactively identify and analyze risk early and often. This allows GitLab to iterate and improve quicker and ultimately provide our customers with a secure and scalable product.

### Schedule / Topics Covered

### RSK101: Risk Management

- Review the different types of risks and their sources- StORM and Third Party Risk
- Learn the main components of risk management
- Perform a TPRM Assessment
- Perform Risk Manager Activities
- You will be given a risk that is reaching a milestone to assess the treatment and potentially validate it's design effectiveness.

### Course Length

6-8 hours over the course of a few days or weeks depending upon your schedule.

Team Manager

Ty Dilbeck, @tdilbeck

Enrollment

Ready to enroll? [Click here for more information.](#)

---

## SECTION: security/security-shadow.md

From converging on real-time critical events with SIRT, exploiting vulnerabilities with the Red Team or participating in live Customer Assurance calls with the Risk and Field Security team, you will have the opportunity to work next to security staff to gain valuable insight and working knowledge of security fundamentals across multiple domains. Each program includes hands-on activities to provide an authentic security team experience.

The Security Shadow program is designed to provide numerous benefits including

- Provide insight and transparency into the operations of various security teams
- Educate and expand skillsets of interested team members
- Strengthen collaboration and working relationships with participants

How the Security Shadow Program works

Each security team may host 1 individual at a time. Availability of each team is determined by the team manager. After completing the enrollment form a schedule will be agreed upon between you and the applicable team manager. The course schedule for each team ranges from 2 to 4 days and between 2 to 4 hours per day (see course catalog below). You will then be paired with the team and provided a calendar invite with zoom link to join each day on the agreed upon time and schedule. Learn, participate, ask questions and enjoy the experience.

Course Catalog

Our course catalog is divided into three main areas in alignment with the three Sub-Organizations within the Security Department.

- Product Security
- Security Operations
- Security Assurance

Who can join the Security Shadow Program

All GitLab team members are welcome!

Enrollment

Ready to embark on this adventure with us?

1. Talk to your manager. Make sure they approve the time you will need to dedicate to this program.

1. Fill out the issue template and assign to the applicable manager(s) of the course you are interested in participating in.

1. The manager of the applicable Security Team will reach out to schedule your start date

## Questions

Feel free to contact the Security Team in our Slack Channel

---

## SECTION: security/transparency-by-default.md

## Purpose

In alignment with our company value of Transparency, one focus of the security organization is to lead the most transparent security organization in business today. Transparency by default requires us to challenge the status quo where security teams traditionally operate in a very private and closed-off manner. However, being open by default requires us to be even more diligent in our efforts of categorizing data in order to ensure the protection of our customers, company, and team member data. Therefore, our position is that all information and activities produced by the security team should be considered "Public by Default" unless defined below:

### Open to GitLab, Partners, Customers

This information is only externally available to GitLab Partners or Customers as widespread availability of this data can be damaging to GitLab or risk the security or privacy of GitLab, GitLab customers or GitLab partners.

- Control status
- 3rd party audit reports
- RFP database responses
- 3rd party penetration test report summaries
- Aggregate vulnerability metrics (by severity only)
- Security Team Roadmap

### Open to GitLab

This information is open to GitLab but not publicly (handbook) available because of information that can risk the confidentiality, security or privacy of internal company information. The public availability of this information could pose a significant risk to GitLab or its customers.

- Vendor Audit Reports
- Procedures/Runbooks/work instructions containing sensitive or personal data
- Customer questionnaires
- Detailed control test results to include observations and remediation plans
- Gap analysis reports

- Project management documentation containing sensitive or personal data
- Security metrics
- Security KPIs
- Security OKRs
- Unmitigated vulnerabilities
- HackerOne vulnerability submissions post internal triage
- 3rd party penetration test full detail reports
- Information about security incidents or investigations handled by SIRT that are not considered high-severity or sensitive
- Red Team operation reports.
- Vulnerabilities patched or resolved more than 30 days ago
- Concluded security incidents that do not contain Materially Non-Public Information

Restricted: Security Only or other restrictions imposed

This information is restricted due to confidential data or privacy concerns related to company, customer or individual data that would be significantly damaging if disclosed or otherwise restricted by law or by legal contract.

- Customer contracts / Open to Security Only (and Legal, Sales)
  - Due to confidential customer data
- Open/closed security customer support tickets / Open to (Security, Support)
  - Due to customer, individual privacy requirements
- Audit Evidence
  - Due to the sensitive nature of the data being provided which can include personal data, system data and current risks including open vulnerabilities
- Legal Holds
- Work communication (emails, Slack) related to specific topics or team members
- Risk Register
- HackerOne vulnerability submissions prior to internal triage
- Critical preventative or detective security control configurations
- Baseline security configurations
- Vulnerabilities that are unique to the FedRAMP production environment
- Information related to GitLab.com abusive activity and follow-up activity taken by the Trust & Safety team
  - Due to customer, individual privacy requirements
  - Due to the necessity to keep our anti-abuse processes unknown to abusive actors
- Information about security incidents or investigations that have not yet been marked as closed/resolved by the SIRT, or incidents or investigations that if made more transparent, may be harmful to team members, GitLab, or its customers
  - Due to the sensitive nature of security incidents and the information involved (unpatched vulnerabilities, compromised credentials)

---

## SECTION: security/women-in-security.md

Women in Security Mission Statement

GitLab's Women in Security group is established to provide support, skills and leadership

development, and networking and mentorship opportunities for the women in GitLab's security department. The group also seeks to inspire women and girls interested in entering or learning about the security industry.

### Membership

While tailored for current female team members of the GitLab Security organization, we encourage and welcome the participation of all GitLab members who are dedicated to the support of women in the security industry.

### Programs

- AMAs tailored to leadership and networking
- Mentorship
- Social outreach
- Publications

### Leadership Sponsor

Julie Davila, VP Product Security

### Catalog of Events and Publications

- Applying Risk Management to Pandemic-driven Remote Learning
- Understanding Compliance: Liz Coleman
- Understanding Compliance: Meghan Maneval
- WIS Blog 1: How to break into security
- WIS AMA Series 1, Karen Blasing
- WIS Blog 2: What's it like to work in security at GitLab?
- WIS Blog 3: Considering a career in security? Here's some advice.
- WIS AMA Series 2, Vanessa Pegueros

---

## SECTION: security/working-in-security.md

### Security Hiring

The company-wide mandate is justification for mapping Security headcount to around 5% of total company headcount. Tying Security Department growth headcount to 5% of total company headcount ensures adequate staffing support for the following (below are highlights and not the entire list of responsibilities of the Security Department):

- Security releases. At GitLab, the Security Department is DRI for critical and non-critical security releases.
- Detection/response for security incidents, which will increase as GitLab.com users increase.
- Preparation for becoming a public company.
- Running the GitLab public bug bounty program.
- Dogfooding and contributing to our product.
- Improving and maintaining the security of GitLab.com and related services.

## Career Development and Opportunities at GitLab

Career opportunities at GitLab, personal growth, and development are important and encouraged. Security team members and managers are encouraged to use Individual Development Plans to help foster, guide, and assist with career growth.

Information regarding growth and development benefits available to GitLab team members is available on the General & Entity Specific Benefits page, with specific information regarding general budgeting strategy, reimbursement requirements, and budget exceptions for tuition available in the Growth and Development Benefit section of that page. Eligibility information and directions on how to apply for growth and development benefits can be found on the Growth and Development Benefit page. Be sure to review the administration process for growth and development costs exceeding \$1000 before proceeding with payment as the reimbursement process and timing differs depending on category.

### Individual Contribution vs. Management

mermaid

graph LR;

subgraph Merit Based

sec:s(Intern, Product Security)-->sec:se(Security Engineer);

sec:se(Security Engineer)-->sec:sse(Senior Security Engineer);

end

subgraph Based on Merit and Company Need

sec:sse(Senior Security Engineer)-->sec:stse(Staff Security Engineer);

sec:stse(Staff Security Engineer)-->sec:pse(Principal Security Engineer);

sec:pse(Principal Security Engineer)-->sec:dse(Distinguished Security Engineer);

sec:sse(Senior Security Engineer)-->sec:sem(Manager, Security);

sec:sem(Manager, Security)-->sec:sms(Senior Manager, Security)

sec:sms(Senior Manager, Security)-->sec:ds(Director of Security);

end

click sec:s "/job-families/security/security-engineerintern"

click sec:se "/job-families/security/security-engineerintermediate-security-engineer";

click sec:sse "/job-families/security/security-engineerssenior-security-engineer";

click sec:stse "/job-families/security/security-engineerstaff-security-engineer";

click sec:pse "/job-families/security/security-engineerprincipal-security-engineer";

click sec:dse "/job-families/security/security-engineerdistinguished-security-engineer";

click sec:sem "security-leadership";

click sec:sms "security-leadership";

click sec:ds "security-leadership";

### Security Internship

For information on the security internship, see the Internship page.

### Security Shadow Program

The Security Organization is piloting a fully immersive on-the-job cross-training program among our various sub-organizations and teams. Participants will get a true behind the scenes look at



how the Security Organization protects, defends, and assures our customers and team members day in and day out.

For more information, see the Security Shadow Program page.

## Security Gearing Ratios

Gearing ratios related to the Security Department have been moved to a separate page.

---

## SECTION: security/best-practices/google-cloud-security-best-practices.md

## Google Cloud Resources

Some Google Cloud resources, if deployed with default settings, may introduce risk to shared environments. For example, you may be deploying a temporary development instance that will never contain any sensitive data. But if that instance is not properly secured, it could potentially be compromised and used as a gateway to other, more sensitive resources inside the same project.

Below are some steps you can take to reduce these risks.

### Google Compute Instances

#### Service Accounts

By default, Google will attach what is called the Compute Engine default service account to newly launched Compute Instances. This grants every process running on your new Compute Instance 'Project Editor' rights, meaning that if someone gains access to your instance they gain access to everything else in the project as well.

This default account should not be used. Instead, you should choose one of the following two options:

- If your instance does not need authenticated access to Google Cloud APIs, you should choose not to bind any service account at all. This can be done by appending the `--no-service-account` `--no-scopes` flags if using the `gcloud` command, or by selecting the following option in the web interface:

- If your instance does need to authenticate to certain Google Cloud APIs, you should use a specific service account that has been granted only the minimum IAM roles required for your application to function. Access Scopes are not a replacement for properly configured IAM permissions and in general should not be relied upon as a security mechanism.

### Firewall Rules

When permitting access to Compute Instances via firewall rules, you should ensure you are

exposing only the minimum ports to only the minimum instances required.

When creating a new firewall rule, you can choose to apply it to one of the following "Targets":

- All instances in the network: This is probably not the option you want. Selecting this option is a common mistake and may expose insecure services on instances other than your own.
- Specified target tags: This is probably the option you want. This allows you to limit the rule to instances that are marked with a specific network tag. You should create a descriptive tag name like "allow-https-from-all" so that it can be easily identified and used when needed.
- Specified service account: This is a less likely option, but perfectly viable if you have already done some design around custom service accounts. It is similar to a tag but will be assigned automatically to all instances using a specific service account.

When choosing "Ports and Protocols" to expose, you should never select "Allow All" and should never manually enter entire ranges such as 1-65535. Instead, you should choose only the specific required TCP/UDP ports you need to expose.

## Google Kubernetes Engine Clusters

GKE nodes are Compute Instances, and by default use the same Compute Engine default service account described above. Despite making it their default, Google specifically states "You should create and use a minimally privileged service account to run your GKE cluster instead of using the Compute Engine default service account."

Whether deploying a GKE cluster manually or automatically via Terraform, you can follow these instructions to create and attach a service account with the minimum permissions required for a GKE cluster node to function.

In addition, you should enable Workload Identity and Shielded Nodes on all new clusters. This can be done by appending the `--workload-pool=[PROJECT-ID].svc.id.goog` `--enable-shielded-nodes` flags if using the `gcloud` command, or by selecting the following options in the web interface (located under the "Security" menu):

## Google Cloud Functions

### Access Control

When creating a Cloud Function with a "trigger type" of HTTP, Google provides two layers of access control. The first is an identity check, via the following two options under Authentication:

- Allow unauthenticated invocations: This will permit anyone on the Internet to invoke your function, supplying any type of input parameters they choose. This option should be avoided where possible.
- Require authentication: This will allow you to manage authorized users via Google Cloud. This is the preferred option.

The second is network-based access control, via the following options under Advanced Settings -> Connections -> Ingress Settings. You should choose the least permissive option that will still allow your function to work:

- Allow all traffic: This will permit HTTP invocations from any IP address.
- Allow internal traffic only: This restricts invocations to a source in the same Google Cloud project or the same VPC SC perimeter.
- Allow internal traffic and traffic from Cloud Load Balancing: This is the same as above with the added ability to send an invocation through Google's load balancers.

Some use cases will prevent you from choosing the "best practice" when it comes to authenticating an inbound request. For example, you may wish to host a webhook target for an external service that doesn't support the use of Google Cloud credentials. For this use case, you can store a complex, machine-generated secret as an environment variable inside your function and then ensure the requesting service includes that secret inside the request headers or JSON payload. More details and examples can be found [here](#).

### Service Account

Similar to Compute Instances and GKE clusters, Cloud Functions also bind to a service account by default. And once again, Google states that "it's likely too permissive for what your function needs in production, and you'll want to configure it for least privilege access".

For most simple functions, this shouldn't be an issue. However, it is possible that a complex function could be abused to allow the person invoking the function to impersonate that service account. For this reason, you'll want to configure a new service account with the bare minimum permissions required for your function to operate.

You can then choose to use this new service account via the option under Advanced Settings -> Advanced -> Service account.

### GitLab Demo and Test Instances

Test and demo instances are publicly accessible on the internet, by default. There may be occasions where team members need to test specific GitLab versions or configurations affected by known security vulnerabilities. It is your responsibility to secure your test instances to prevent them from being compromised or used in ways that could compromise our cloud environment. If you need help securing your instance or have a question, feel free to ask in the security channel in Slack.

### IP Filtering

A highly effective way to secure your cloud instances is to apply the concept of IP filtering for each test instance you create whether it's a GitLab instance or otherwise. For the majority of cases, this means source IP filtering from one or more CIDR block ranges ensuring that only certain IPs and integrations can interact with the GitLab instance, therefore reducing the attack surface of the GitLab organization as a whole.

If you don't know your current IP address to use for source IP filtering, you can utilize services like [whatsmyipaddress.com](https://whatsmyipaddress.com) or [ipinfo.io](https://ipinfo.io) to retrieve it. The steps to implement IP

filtering will differ per cloud environment. Below you can find a detailed guide maintained by the support engineering team.

- Support Engineering Step-by-Step Guide to Implementing IP Filtering

In addition, you can find official, platform-specific documentation of features involved in implementing IP filtering:

- Google Cloud
- Amazon Web Services (AWS)
- Azure

IP filtering should be set up and used when hosting any version of GitLab affected by known and disclosed vulnerabilities.

You can view a list of vulnerabilities affecting a given version of GitLab [here](#). Versions of GitLab without the latest security patches and fixes applied should not be publicly accessible.

### Classified Data

Do not host or store any classified data on test or demo instances.

For public-facing instances, only Green data is allowed.

RED, ORANGE, and YELLOW classified data, along with customer data and personal data, should never be copied to or stored on test or demo instances.

### Clean Up

Test instances should be ephemeral.

As soon as you've finished testing, or you've finished your demo, shut down or destroy the test environment.

If this test or demo environment will be live for a substantial amount of time (>24 hours), plan a decommission date and set a reminder for to ensure the instance is shut down or destroyed in a timely manner.

### Upgrade regularly

For test or demo instances that will be live for an extended period of time, it's important to regularly update GitLab and other software on the machine to ensure the all latest security patches have been applied.

Establish a plan to update GitLab after every security release, and update system packages at least once a week.

Set a reminder for yourself to ensure you apply GitLab security updates in a timely manner.

Also, remember to clean up the instance as soon as your test or demo is has concluded.

## Secure GitLab Application Settings

- Disable New User Registration
- Do not use instance-level shared Runners

## Use HTTPS

To be in line with GitLab's encryption policy, TLS should also be implemented on public-facing testing resources. For GitLab instances, you can use the LetsEncrypt integration. Let's Encrypt is enabled by default if `externalurl` is set with the HTTPS protocol and no other certificates are configured.

---

## SECTION: security/best-practices/supply-chain-security-for-dependencies.md

## Overview

Software supply chain security has become increasingly critical as modern applications, including GitLab products, rely heavily on third-party open source dependencies and libraries. A single compromised dependency can result in serious real-world consequences. This guide provides developers and security team members with best practices and considerations for evaluating and securely using open source dependencies in their projects.

## When to Use These Guidelines

Apply these guidelines when:

- Reviewing merge requests (MRs) that add new dependencies
- Evaluating updates to existing dependencies
- Auditing current dependencies for security

This includes changes to:

- Library manifests (e.g., Gemfile, package.json, go.mod)
- Lockfiles (e.g., Gemfile.lock, yarn.lock, go.sum)
- Vended dependencies

## Dependency Evaluation Process

### Evaluate the Need for the Dependency

Before adding a new dependency, first evaluate whether it's truly necessary:

- How much of the dependency's functionality will you actually use?
- Could the needed functionality be implemented directly with a reasonable amount of code?
- Would maintaining this code yourself be simpler than managing a new dependency?
- Is the dependency solving a complex problem (like cryptography) that should not be implemented in-house?
- Does the dependency have other dependencies that would also need to be added?

## Initial Risk Assessment

Before diving into detailed evaluation, consider:

- The scope of access and permissions the dependency requires
- The criticality of the component or feature that will use this dependency

## Evaluate Project Health and Secure Development Practices

Note: these criteria are not required to use a dependency, but they are good indicators of the project's health and security.

- Is the project actively developed, maintained, and mature?
  - When was the code last updated?
  - When was the last release shipped?
  - How many releases are there?
  - How frequently are new releases shipped?
  - Is the software dependency version being evaluated a stable "release" version? (for example: not alpha, beta, v0.x)
  - Is the project older than 90 days?
- Is the project well-known or widely adopted in the software industry and open source community?
  - Wide adoption can indicate stability, reliability, and community trust
  - Lesser-known, newer, specialized, or niche dependencies may still be appropriate if they:
    - Meet our security requirements
    - Solve a specific need better than alternatives
  - Note: Low adoption alone is not a disqualifying factor if other security and maintenance criteria are met
- Given the complexity of the project, does the project have a sufficient number of maintainers and contributors?
- Does the project keep its dependencies updated?
- Does the project have sufficient test coverage?
  - Do the project's pipelines or tests include security checks or testing?
- Is the project well-documented and does the document include guidance on how to use or implement the software component securely?
- Does the project have an established and documented process for reporting vulnerabilities and are these vulnerabilities addressed in a timely manner?
- Is the dependency version being evaluated affected by known vulnerabilities or CVEs? If so, is there a fix available?
- Are commits to this project cryptographically signed?
- Does the project have a code review process for changes before code is merged into the main branch?
  - Does the project require approvals for merge/pull requests?
- Are releases signed or cryptographically verifiable?
- Do project maintainers use accounts registered to personal custom email domains?
- Does the project have security requirements for maintainer accounts? (Check project security or contribution requirements, if available)

## Code Inspection

- Review library code for malicious or problematic content
- Inspect the source code
- To help review code changes between dependency versions, use services like [diffend.io](https://diffend.io) for Gems or [app.renovatebot.com](https://app.renovatebot.com) for Node.js modules
- For vendored libraries, use standard code review tools
- Review diffs for dependency upgrades to ensure the upgrade is safe and does not introduce new vulnerabilities or

## Supply Chain Security Best Practices

- Implement Security Scanning: Implement automated vulnerability scanning in your GitLab CI/CD pipeline.
- Verify the package source: Always download packages from trusted sources. Stick to official package repositories or well-known sources that have a good reputation.
- Double-check package names: Pay close attention to the spelling and formatting of package names.
- Verify package integrity: Many package managers provide mechanisms to verify package integrity using checksums or digital signatures.
- Pin dependencies: Use a lockfile or similar mechanism to specify the exact version of a dependency that is used in a project. This can help to prevent the "dependency confusion" attack.
- Plan for security compromise: Consider developing a plan to quickly remove or replace a compromised dependency.

## Dependency review guidelines for AppSec engineers

### Ruby Gems

When a new gem is added to our Gemfile or when versions are changed in Gemfile.lock, we ask developers to reach out to the AppSec team to request a review. As an AppSec engineer performing the review, please refer to the guidelines above and follow the steps mentioned below to perform reviews like these:

- First, look to see if the gem is well maintained.
  - Look closer at the gem's code to see if there are any anomalies. This step can be time consuming, so, make sure you balance the time taken to review the gem's code with the urgency of the MR/issue the GitLab developer pinged us on.
  - The `diffgem` helper function in `gitlab-com/gl-security/product-security/appsec/tooling/appsec-command-line-utils` was created to assist in reviewing gem version changes by showing only the diffs for Ruby files. (excluding changes to specs, json, yaml, and other noise)
  - Depscore if enabled in the project CI/CD will run checks against the new dependency and comments the result in the MR to help with the Gem review.
- Look to see if we are using the latest version of the gem in our code.
- Read the gem's documentation to see if there are any configurations or usages that should be avoided.
- Check for security advisories and fixes to evaluate the quality of security fixes.

After you have done the above, please add a comment to the MR/issue the developer pinged us on mentioning that:

- You have looked at the gem in question. Add a hyperlink to the gem's GitLab/GitHub page.
- Please mention if the gem is well maintained. If it isn't, ask the developer to use alternate gems to do the task they would like to do.
- Please mention if we are using the latest version of the gem in our code. If that isn't the case, ask the developer to move to the latest version.
- If you notice that the developer is using the gem in an insecure manner, recommend secure usages of the gem or disable any insecure configurations in the gem by pointing the developer to the gem's documentation.

## NPM packages

The dependency review guidelines for Gems are applicable for reviewing npm packages as well, in addition to that:

- If npm aliases are noticed verify that the package referred by alias name is not malicious.

---

## SECTION: security/corporate/\_index.md

· Welcome to Corporate Security, we're glad you're here! You may also know us as the former IT Operations team that moved from the Finance to Security division in early 2024.

## Need Help?

Please try exploring the following pages to see if your question has been answered in the handbook pages. If not, please ask in the ithelp channel and one of our Support Analysts will reply as soon as possible.

- CorpSec Onboarding 101 Guide
- CorpSec Support Guide
- CorpSec Services
- CorpSec Systems and Tech Stack Apps
- Internal Handbook
- System Administration and Runbooks Handbook
- Ask in the ithelp Slack channel

## What We Do

### Mission

#### Security Division Mission

As a remote company, we do not have office buildings, physical datacenters, or other traditional IT environments. All of our team members are issued a laptop that they use to work from home or on the road. Although our engineering and product teams are building software that is deployed on AWS and GCP, almost all of our corporate software is vendor-managed software-as-a-service (SaaS). Although this results in a simpler physical threat landscape, the cybersecurity threat landscape is vast and still requires a lot of attention to do it right.



Our mission is to empower our employees to be productive with the technology provided by the business, enable the business to be successful, protect our customers and their data, and provide internal security for GitLab (the company) and our team member's use of GitLab (the product).

GitLab is both a company and a product. The Corporate Security department focuses on protecting the technology that the company uses to conduct business internally, and provides the hardware, software, and tools that our team members need to get their job done. We have a 24x5 technical support helpdesk for team members and have engineers that configure and maintain many of our company-wide tech stack applications. We also invest heavily in device trust and identity management to provide the highest level of security assurance for the administrators of our product and ensure all appropriate controls are in place when handling customer data.

#### Prime Directive

- Safeguard our organization's digital assets, ensuring the integrity, confidentiality, and availability of all data.
- Implement robust security measures, fostering a culture of awareness and compliance among employees, and continuously monitoring and enhancing our information technology systems to protect against evolving threats.
- Leverage the GitLab platform (dogfooding) to assist us in the securing of GitLab.
- Provide reliable, secure and efficient IT and Security engineering, innovation, and services with Zero Trust principals to support cross-functional organizational goals

#### Scope

- Architecting next-generation automation and integration between security-related systems that provides data consistency, reliability, strong security, and auditability.
- Building relationships with cross-department system owners and proposing solutions to ensure our tech stack applications conform to our latest security best practices
- Consolidating and refactoring legacy tech debt
- Designing processes and choosing software tools that improves back office automation or mitigates security risks
- Escalation engineering and crisis response for leadership teams
- Factor in cost, security, compatibility, maintainability and user experience when making decisions
- Growing other team members' skill sets through mentorship to improve operational efficiency and encourage professional development
- Handbook documentation for processes and systems architecture
- Identity and access management (IAM)
- Joint collaboration with process and system owners across the company for improving automation efficiency, security posture, and vulnerability management
- Keeping leaders and stakeholders informed of next-gen initiatives and contributing to creating automated analytics for day-to-day IT and Security operations
- Leading innovation opportunities between several teams with a willingness to experiment and to boldly confront problems of large complexity and scope
- Making technical decisions on behalf of the department and organization while providing presentation support to leaders during technical discussions
- New tech stack (vendor) application onboarding and provisioning
- Onboarding provisioning, offboarding deprovisioning

- Policy and configuration management for organization-wide applications and systems that we manage
- Role-based access control (RBAC)
- Shipping laptops to new team members and refreshing older models
- Tech support for team members and temporary service providers
- User experience and productivity optimization for internal software and tools
- Vulnerability and malware risk mitigation
- Workflow automation for employee lifecycle
- X-Men, we are. Always be saving the day with a smile on your face!
- Yesterday's problems are tomorrow's opportunities for iteration
- Zero trust implementation

## Direction and Strategy

- (Internal) CISO Multi-Year Information Security Goals and Priorities
- (Internal) CorpSec Direction and Strategy
- (Internal) CorpSec OKRs and Roadmap
- (Internal) CorpSec Projects and Initiatives
- Security Division OKRs
- (Internal) Corporate Security Epics List
- (Internal) Corporate Security Epics Gantt Chart
- (Internal) CorpSec Issue Tracker
- How We Work

## Services

- · Please see CorpSec Support if you are looking for help.
- · Applications and Systems
- · Helpdesk Services
  - · Access Requests
  - · Laptop and Logistics Services
  - · Onboarding
  - · Offboarding
  - · Tech Support (for Team Members)
- · Infrastructure Services

## Engineering

- · How We Work
- · Device Trust Engineering
- · Identity Engineering
- · Infrastructure Engineering
- · Platform Engineering
- · SaaS Engineering

## Who We Are

See the Team Directory.

## Contact Us

- Tier 1 Self Service
- Tier 2 Helpdesk Support
- Tier 3 Escalation and Systems Engineering
- Tier 4 Automation Engineering
- Tier 5 Architecture and Crisis Management
- CorpSec Issue Tracker
- Engineers and System Owners - See CorpSec Systems for GitLab group handle and Slack group handle.
- corpsec Slack Channel (for technical support, please ask in ithelp)
- Helpdesk Team
  - ithelp Slack Channel
  - @it-help Slack group
  - it-help [at] gitlab [dot] com
  - @gitlab-com/gl-security/corp/services
- Management Team
  - @gitlab-com/gl-security/corp/managers
  - Tag the respective functional team manager or director in Slack.
    - Director - Steve Manzuik
    - Program Management - Steve Manzuik, Kim Waters
    - Device Trust - Eric Rubin
    - Helpdesk Support - Michael Beltran
    - Infrastructure - Jeff Martin
    - Laptops and Logistics - Michael Beltran
    - Onboarding and Offboarding Day-to-Day Operations (Helpdesk Services) - Michael Beltran
    - Onboarding and Offboarding Policy and Strategy (Identity Engineering) - David Zhu
    - Platform Engineering (Custom Software Development) - Jeff Martin
    - SaaS Engineering - David Zhu, Eric Rubin
    - Sensitive Data or Employment Requests - Michael Beltran

---

## SECTION: security/corporate/automation/\_index.md

---

## SECTION: security/corporate/automation/google-workspace/deprovisioning/\_index.md

Google Workspace deprovisioning is composed of 2 parts that are outlined below. The first part happens as part of the initial offboarding. The second part occurs after 90 days from the offboarding. This workflow will send out notifications throughout this 90 day period to let the Former Team member's manager know that the final deadline is approaching.

These are the steps that follow immediately upon termination of a team-member

- Signs a user out of all web and device sessions and reset their sign-in cookies.
- Update user profile
  - reset password
  - remove from Global Address list

- remove recovery email
- remove recovery phone
- move to /Former Team Members organizational unit
- unsuspend user if suspended
- Remotely wipe corporate Google Workspace data from mobile devices
- Delete access tokens (OAuth tokens)
- Delete application specific passwords (ASPs)
- Delete verification tokens
- Remove user membership from Google groups.
- Create and set a vacation auto-reply in the user's Gmail
- Make manager a Gmail delegate
- Create a transfer request and transfer the following data to the user's manager
  - Google Drive
  - Google Calendar

These are the steps that follow after the Former Team Member has been gone for 90 days

- Update user profile
  - move to /NoGSuiteLicense organizationl unit
- Delete all aliases
- Suspend the user

The following notifications will be sent out to the former team member's manager via Slack

Immediate Slack notification:

```
> Hello <Manager displayName>,
>
>You are receiving this notification to let you know that one of your direct reports <user
fullName> has been deprovisioned from GitLab's Google Workspace.
>
>In keeping with our standard offboarding policy the user's Google Drive and Calendar data has
been transferred to you. You will also receive delegated access to their Gmail account.
Delegate access will remain available to you for 90 days after which the account will be
closed. For more information about how to access this data please see information in the
Handbook page.
>
>You will receive follow-up notifications 30 days and 1 week before this account is closed. If
you have any questions about this process, or need assistance, please feel free to reach out to
the Corp IT team in the ithelp Slack channel.
```

30 Days Slack notification

```
> Hello <Manager displayName>,
>
>You are receiving this notification letting you know that your direct report <user email> was
deprovisioned from GitLab's Google Workspace 60 days ago.
>
>In keeping with our standard offboarding policy you will continue to have delegated access to
their Gmail account for another 30 days after which the account will be closed.
```

>

>If you have any questions about this process, or need assistance, please feel free to reach out to the Corp IT team in the ithelp Slack channel.

#### 7 Days Slack notification

> Hello <Manager displayName>,

>

>You are receiving this notification letting you know that your direct report <user email> was deprovisioned from GitLab's Google Workspace 83 days ago.

>

>In keeping with our standard offboarding policy you will continue to have delegated access to their Gmail account for another 7 days after which the account will be closed.

>

>If you have any questions about this process, or need assistance, please feel free to reach out to the Corp IT team in the ithelp Slack channel.

#### Final Slack notification

>The GitLab Google Workspace account for <user email> has been archived after 90 days as per our standard offboarding policy.

#### FAQ

The team member had a Gmail thread with a customer. How can I get that thread history? How long will it be available?

> Delegate access to the former team member's gmail account will be provided to the manager. Access will be available for 90 days following initial offboarding.

>

> For example, to access a former team member's email thread with a customer:

>

>- Open Gmail in a browser

>- Select your user profile in the top-right corner

>- From the dropdown of available accounts, select the gmail account you wish to view. A delegated account will be marked with a Delegated label.

The team manager owned a calendar invite that had external collaborators (customers, partners, etc). How do we cancel that event or I can take over as the organizer? I want the best UX for my customer.

> Former team member's primary calendar are automatically transferred to the manager when they are initially offboarded. If you are the manager, you will receive an email with the link to the calendar and direct access in Google Calendar. Existing calendar events can be cancelled or have their ownership transferred like any other event in Google Calendar.

I'm not the team member's manager, just a peer, and they have a document that I need to get access to. I don't know the document name, only the ID. How can I learn more about what's inside this document. How can get me access?

> If you know the team member's manager, you can request for them to share the file with you directly. Otherwise, please create an AR using the IndividualBulkAccessRequest template with the following:

>

- >- Manager approval
- >- it-security label
- >- Link(s) to the document(s)
- >- Who we should transfer ownership to

How long will the team member's Google Docs be available before they are lost or destroyed?

> The team member's Google Docs will not be destroyed. They will be transferred directly to the team member's manager.

If the team member's manager leaves the company (at the same time or in a few months), what happens to the original team member's data? How can we access it, and for how long?

> If the manager leaves GitLab around the same time as the team member, Google Drive and Google Calendar data for both the team member and manager will be transferred to the manager's manager.

The team member was an owner/editor of a Google Doc in a shared drive that I can see but only have viewer/commenter access. How do I get Editor access since the emails to request access were sent to their email? Is there a standardized or automated way to do this without opening an AR?

> in Google Workspace Share drives and myDrives (personal drive) operate differently. Files in Share Drives are owned directly by the Share Drive itself, while myDrive files are owned by the user. If you need access or additional permissions to a Share Drive file, make an Access Request and include as much information about the file as possible.

A customer is emailing the former team member and even if they are getting a vacation response, they haven't opened a new thread with someone else. I'm worried about needing to stay in contact with that customer. What should I do? How can we maintain a great customer experience?

> If you are their manager you can use Gmail delegate access to access their email and let the customer know to open a new email thread with the appropriate contacts. Otherwise, please work with their manager in handling updated communications with the customer.

I heard that the team member was sent a message last year that had a PDF attachment that I need now. What's the process for searching their email for that message?

> If you are their manager you can use Gmail delegate access to access their email and find the PDF attachment. If delegate access has expired, you can file an access request to have the email and PDF attachment transferred to you.

For Security reasons, data security, compliance, and the other good reasons, who has administrative access to all this data? Who can help me? Who doesn't get access and why?

> Administrative access to not only offboarded team member data, but Google Workspace overall,

is limited to members of the Corporate Security team. Access is restricted further to only those who need administrative permission as part of their day to day duties. This follows the principle of least privileges and helps keep corporate data private and secure.

I have delegated access to a former team members calendar, docs, and email. What should or should I not do? What data privacy concerns should I be concerned about? If I see something weird or personal inadvertently, should I report it to People Ops or Security, or just ignore it?

> First, if you see anything unusual or personally sensitive, please report it to the Security team immediately.

>

> While you have delegate access to the user's Gmail account, please be mindful of responding to emails as the former team member. Instead, forward the email to yourself and respond to the forwarded email from your account.

A former team member had access to confidential financial insider information or a confidential codename project. What processes are in place to protect that data from being shared with other team members who are not approved to see it?

> An offboarded users data is only shared with those who already had access or their manager as part of the transfer process. No additional access is granted.

---

## SECTION: security/corporate/automation/slack/helpdesk/\_index.md

## Overview

When you ask for help in the ithelp channel, this automation will automatically create a new GitLab issue that creates a long term record of your support request, while providing the ease-of-use of a Slack thread.

Each comment in the Slack thread is added to the GitLab issue.

This allows us to dogfood GitLab, and also link to related GitLab issues if additional triage is needed or we are cross-linking the audit trail of change management activity, laptop requests, etc.

## Technical Details

### IT-Help Slack Issue Creator wiki

The script scans the IT help Slack channel and performs the following actions:

- Creates a new GitLab issue if a user adds an 🗑️ reaction to a message and the issue has not been created yet.
- Closes the GitLab issue if a user adds a check mark (✅) reaction and the issue has been created but not closed.
- Reopens the GitLab issue if it has been closed, but the check mark reaction is removed.

- Adds system labels to the GitLab issue based on specific emoji reactions in the Slack channel.
- Parses the Slack thread and adds comments to the related GitLab issue.
- Adds comments from GitLab issue into Slack thread.

---

## SECTION: security/corporate/direction/\_index.md

Thank you for your interest in the direction of Corporate Security. See the internal handbook for our direction and roadmap with OKRs.

---

## SECTION: security/corporate/end-user-services/\_index.md

## How to Contact Us

You can reach us via the following channels:

Email: [it-help@gitlab.com](mailto:it-help@gitlab.com)

Slack: [ithelp](#) / [@gitlab-help](#)

## Important Links

### IT Onboarding Guide

Please see GitLab IT Onboarding 101 and reach out to us directly with any questions or concerns.

### Laptop Wipes

To book an appointment with us to wipe a GitLab laptop as part of a hardware refresh or offboarding, please refer to our Laptop Wipe (Factory Reset) Process page and reach out to us directly with any questions or concerns.

### CorpSec Support

For guides for many of our most frequently asked questions, please see CorpSec Support

<!-- Old EUS site below

<link rel="stylesheet" type="text/css" href="/stylesheets/biztech.css" />

<i class="far fa-paper-plane" id="biz-tech-icons"></i> How to reach out to us?

<div class="flex-row" style="display: flex; flex-wrap: wrap; height: auto; justify-content: space-between;">



[Open an issue](https://gitlab.com/gitlab-com/it/end-user-services/issues/it-help-issue-tracker/-/issues/new?issuabletemplate=GeneralHelpDeskRequest)  
[it-help in slack](https://gitlab.slack.com/archives/CK4EQH50E)  
[What timezone are we located in?](https://www.worldtimebuddy.com/?pl=1&lid=4143861,4726206,2964574,2158177&h=4143861)

*Frequently visited pages*

#### Access Requests

- For information about the access request policies and security guidelines, please refer to the Security Team's access request handbook page section.
- For links to role based access request templates, system access templates, and other general instructions and FAQs, please refer to the Access Requests page.

#### Baseline & Role-Based Entitlements

- For information about baseline entitlements and role-based access, please refer to the baseline entitlements handbook page.
- For information on how to create a Role-Based Entitlement, please refer to the instructions on how to create role-based entitlements.

#### Automated Group Membership Reports for Managers

If you would like to check whether or not a team-member is a member of a Slack or a Google Workspace group, you can view the following automated group membership reports:

- Google Workspace Group Membership Reports
- Slack Group Membership Reports

#### Okta

To read more about Okta, please visit the Okta page of the handbook.

#### Jamf (Endpoint Management)

To read more about our Jamf deployment please visit the Endpoint Management page of the handbook

#### Laptop Delivery Metrics

To view laptop delivery metrics and statistic please visit the [Laptop Metrics Handbook Page](#)

## GitLab Onboarding and machine management

Please visit the [GitLab Onboarding and machine management handbook page](#)

## GitLab Laptop Offboarding

Please visit the [GitLab Laptop Offboarding page](#) for information pertaining to this process at [GitLab handbook page](#)

## Self-help and troubleshooting

Experiencing some issues with your machine, access to systems, 2FA or other IT related issues? Please visit our [self-help and troubleshooting handbook page](#)

## GitLab IT 101

New to GitLab and looking for some IT tips and tricks? This is the spot for you, we have created a comprehensive guide for using the IT systems, apps and hardware in this [handbook page](#)

## Offboarding

- Are you or a direct report leaving the company? Please reference the [Offboarding handbook page](#) to see the action items that you can take to create a smooth transition for you and your team.

## Automations

### IT-Help Slack Issue Creator

This automation converts Slack threads from the ithelp channel to issues in GitLab. With most IT support requests being handled in the ithelp Slack channel today, this automation will create one basic intake point with bilateral synchronization to GitLab helpdesk issues.

### How to use it

Reach out to the ithelp Slack channel as usual when assistance is needed. The automation will then create, update, and manage an issue created for the Slack thread. You will be able to communicate with the IT Analyst either via the Slack thread or in the issue created by the automation, and responses will sync in both places.

### How it works

The script scans the IT help Slack channel and performs the following actions:

- Creates a new GitLab issue if a user adds an 📌 reaction to a message and the issue has not been created yet.
- Closes the GitLab issue if a user adds a check mark (✅) reaction and the issue has been created but not closed.

- Reopens the GitLab issue if it has been closed, but the check mark reaction is removed.
- Adds system labels to the GitLab issue based on specific emoji reactions in the Slack channel.
- Parses the Slack thread and adds comments to the related GitLab issue.
- Adds comments from GitLab issue into Slack thread.

{{% alert color="info" %}}

To learn more on how this automation works, check the IT-Help Slack Issue Creator wiki.

{{% /alert %}}

*<i class="fas fa-rocket" id="biz-tech-icons"></i>* Mission Statement

## IT Help

- IT Help will triage all IT related questions as they arise.
- Build a knowledge base of IT practices and pragmatic problem solving in the handbook.
- Account management for password resets and logout.
- On call support for immediate software and hardware issues during local business hours.
- Diagnose computer errors and provide technical support.
- Troubleshoot software and hardware.
- Support Weekly IT Onboarding Sessions for new Team Members.
- Train end-users how to setup and use new technologies. Provide technical support over the phone or Web.
- Use specialized help desk support software to take control of end-users' computers to troubleshoot, diagnose, and resolve complex issues.

## IT Holiday Schedule

The IT Helpdesk team (End User Services) will observe two holidays:

| Date                         | Holiday        |
|------------------------------|----------------|
| Wednesday, December 25, 2024 | Christmas Day  |
| Wednesday, January 01, 2025  | New Year's Day |

If you have an urgent request, please reach out to us via slack in the ithelp channel.

## IT Ops

- IT Ops will work with Security, the People Group, and Business Technology to develop automated on-boarding and off-boarding processes.

- We will develop secure integrations between Enterprise Business Systems and with our Data Warehouse.
- We will develop tooling and process to facilitate end-user asset management, provisioning and tracking.
- We will work to build API Integrations from the HRIS to third party systems and GitLab.com.
- We triage IT related questions as they arise.
- We build and maintain cross-functional relationships with internal teams to champion initiatives.
- We will spearhead on-boarding and off-boarding automation efforts with a variety of custom API integrations, including GitLab.com and third-party resources, not limited to our tech-stack, with scalability in mind.

#### GitLab IT Team

- Sr. Director. CorpSec Engineering, Identity, IT End User Support Steve Manzuik, smanzuik@gitlab.com @smanzuik
- Senior Manager, IT - Michael Beltran, mbeltran@gitlab.com, @mbeeee
- IT Analyst Americas - Alex Krusiec, akrusiec@gitlab.com, @akrusiec
- IT Analyst Americas - Jeff Ford, jford@gitlab.com, @jefford
- Senior IT Analyst Americas - Jenny Wong, jwong@gitlab.com, @jwong6
- Senior IT Analyst Americas - Madison Spry, mspry@gitlab.com, @msprygl
- IT Analyst APAC - Max Hirata, mraetz@gitlab.com, @mhirata-gl
- IT Analyst APAC - Bryan Mathews, bmathews@gitlab.com, @bryannoel
- IT Analyst EMEA - Bruno Ferreira, bferreira@gitlab.com, @bruno.n.ferreira
- Senior IT Analyst EMEA - Eoghan Dunne, edunne@gitlab.com, @edunne-gl
- IT Analyst EMEA - Laurie McClafferty, lmcclafferty@gitlab.com, @laurie.mcc
- IT Global Logistics - Mic Rohr, mrohr@gitlab.com, @microhr

#### Laptop Wipe Schedules for IT Analysts

- Mic Rohr - appointment schedule - AMER
- Jeff Ford - appointment schedule - AMER

- Alex Kruseic - appointment schedule - AMER
- Jenny Wong - appointment schedule - AMER
- Madison Spry - appointment schedule - AMER
- Max Hirata - appointment schedule - APAC
- Bryan Mathews appointment schedule - APAC
- Bruno Ferreira - appointment schedule - EMEA
- Eoghan Dunne - appointment schedule - EMEA
- Laurie McClafferty - appointment schedule - EMEA

-->

---

## SECTION: security/corporate/end-user-services/how-to-articles/google-workspace/gmail-delegation/index.md

## Introduction

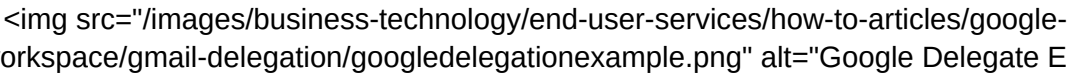
The purpose of this handbook page is to describe how to utilize Gmail Delegation. Gmail delegation gives the ability to access another individuals Gmail Inbox.

## How To Access Delegates

### Using mail.google.com

{{% panel header="Note" header-bg="info" %}}  
 Gmail Delegation is only available via the Gmail Webpage  
 {{% /panel %}}

1. Log into mail.google.com with your GitLab email address

1. In the top right corner of mail.google.com click on your Gmail Profile  

 

1. If you have delegation access you will see the team members account under your Gmail Account.

1. Click on the team members account

- This will bring you to the team members inbox.
- You will be able to view and send emails on behalf of the team member.

---

## SECTION: security/corporate/end-user-services/how-to-articles/google-workspace/google-calendar-delegation/index.md

## Introduction

The purpose of this handbook page is to describe how to utilize Google Calendar Delegation. Google Calendar delegation gives the ability to for a team member to access another team member's Google Calendar.

There are different Levels of Permissions that can be assigned to Google Calendar Delegation.

## How to Add A Google Calendar Delegate

Using calendar.google.com

1. Log into calendar.google.com with your GitLab email address
1. In the top right click on the Gear icon to go into the Google Calendar Settings
1. Select your calendar under the Settings for my calendars
1. Under your calendar settings drop down menu select Share with specific people  
<br>
1. Select + Add People
1. Add the email addresses of the individual to share your calendar with.<br><br>
1. Select the Permissions drop down menu and give the individual the appropriate access. Please refer to Calendar Permission Levels<br><br>
1. Select Send

## Calendar Permission Levels

- See only free/busy (hide details) - The team member will only be able to see if you are free or busy on the calendar
- See all event details - The team member will be able to see all of your calendar events, but will not be able to edit them

- Make changes to events - The team member will be able to edit your calendar events. They will also gain the ability to edit the event details.

- Make changes and manage sharing - The team member will be able to edit your calendar events. They will also gain the ability to edit the event details. They will also gain the ability to change your calendar sharing settings.

## How To Access Google Calendar Delegation

Using [calendar.google.com](https://calendar.google.com)

1. Log into [calendar.google.com](https://calendar.google.com) with your GitLab email address

1. On the left-hand side menu bar navigate to Other calendars and click on the + symbol to Subscribe to calendar<br>



1. Search for the team member whose calendar you want to subscribe to<br>



1. Now when you go back to your calendar you will see the team members calendar under My calendars

1. Depending on the permissions the team member has given you, you will be able to either view or view and edit their calendar events

---

## SECTION: security/corporate/end-user-services/how-to-articles/google-workspace/google-drive-sharing/index.md

## Introduction

The purpose of this handbook page is to describe how to utilize Google Drive Sharing. Google Drive sharing gives the ability to access another team members Google Drive File or Google Drive Folder that is stored in their My Drive.

There are different Levels of Permissions that can be assigned to Google Drive Sharing.

## How to Share Google Drive Files

{{% panel header="Note" header-bg="info" %}}

There are multiple ways to share Google Drive files and folders.

{{% /panel %}}

Using [drive.google.com](https://drive.google.com)

1. Log into drive.google.com with your GitLab email address

1. Navigate to the file or folder you wish to share

1. Right Click on the file or folder

1. Select Share<br>

<br>

1. Add the email address of the individual(s) you wish to share the file or folder with<br>

<br>